Ethical Hacking Assignment 1

ITA14 Ethical Hacking ASSIGNMENT 1

.

CO1

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Assignment 1 Title : Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

Scenario — University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third
party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme.

The framework must define how an engagement is authorized, how scope and rules of engagement are set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade-offs involved.

TASK 1 – Formulate the Enquiry and Framework Blueprint 4 Marks • Convert the scenario into a formal set of engagement-governance requirements. Identify the systems in scope, the stakeholders, the expected activities and the constraints.

• Create a framework blueprint showing how authorization, scope, legal compliance, threat modelling, lab testing and disclosure will cooperate in the proposed programme.

• Formulate at least four enquiry questions that your framework must answer, such as who authorizes a test, what is in scope, which laws apply and how findings are disclosed.

• Define at least five design criteria and use them as acceptance criteria for the final framework.

Evidence Expected

A requirements-to-governance blueprint, enquiry questions, design criteria and a clear rationale showing how the proposed framework addresses the scenario.

TASK 2 – Design a Hacker Threat Model and Classification 4 Marks • Design a classification of the types of hackers relevant to the university, such as white-hat, black-hat, grey-hat, script kiddie, hacktivist, insider and state-sponsored actors.

• Map each type to its motivation, typical capability and likely targets within the university. • Establish clear criteria and naming so that an actor can be classified consistently. • Demonstrate at least two alternative ways of classifying one borderline actor, then choose and justify the final classification.

Evidence Expected

A documented hacker threat model, classification criteria, a mapping table, rejected alternatives and a justified final classification.

TASK 3 – Create an Ethics and Code-of-Conduct Module 4 Marks • Define the ethical principles that govern an authorized engagement, such as written authorization, agreed scope, confidentiality, integrity, avoiding harm and honest reporting.

• Design rules or checks that help detect or prevent unethical actions during an engagement. • Construct scenario cases containing acceptable, borderline and unacceptable actions and show how the code of conduct responds to each.

• Explain how the module preserves trust and keeps the engagement lawful and professional.

Evidence Expected
A reusable code-of-conduct module, decision rules, scenario test cases and evidence that the rules separate acceptable from unacceptable actions.

TASK 4 – Construct a Legal-Compliance Mapping 4 Marks • Map the engagement to the relevant provisions of the Information Technology Act, 2000 on unauthorized access and data, and compare them with an international law such as the Computer Fraud and Abuse Act.
• Build a table of offences, obligations and penalties related to unauthorized access and data protection. • Connect each legal requirement to a specific control in the engagement framework. • Decide and justify which legal requirements apply when a test touches systems that hold personal data.

Evidence Expected
A legal-compliance mapping, an offences-and-penalties table, the controls linked to each requirement and a justified conclusion on which laws apply.

TASK 5 – Create a Scope and Rules-of-Engagement Document 4 Marks • Design a scope and rules-of-engagement (RoE) document that defines in-scope and out-of-scope systems, testing windows, permitted and prohibited techniques and escalation paths. • Create rules for recording and verifying the written authorization behind each engagement. • Establish clear naming and boundaries so that an out-of-scope request can be detected. • Construct at least one transformation of the RoE into a pre-engagement checklist.

Evidence Expected
A complete RoE document, authorization-verification rules, scope boundaries and a derived pre engagement checklist.

TASK 6 – Build an Authorization and Disclosure Layer 5 Marks • Create an authorization workflow covering the request, approval, written sign-off and recording of each engagement.
• Design a responsible (coordinated) disclosure process with a reporting format, remediation window and timeline, and compare it with full disclosure and bug-bounty approaches.
• Develop operations for logging approvals and status updates and for deciding when disclosure may proceed.
• Create rules for choosing between coordinated and full disclosure for a given finding. • Demonstrate that this layer interacts correctly with the rules-of-engagement and legal-compliance components.

Evidence Expected
An authorization workflow, a responsible-disclosure process, logging and decision operations, disclosure rules and evidence of interaction with the other components.

TASK 7 – Design an Isolated Ethical-Hacking Lab 5 Marks • Design a safe, isolated lab using a Kali

Linux machine and one or more authorized target machines on a host-only network with reserved addresses such as 192.168.56.0/24.

• Specify the components, roles and connectivity of the lab and the steps used to record its configuration.

• Develop at least two operations, such as verifying connectivity between the machines and recording the lab setup.

• Construct a small comparison between a host-only and a NAT lab network and justify the chosen design.

• Explain how the lab keeps all testing authorized and contained within the isolated environment.

Evidence Expected

An isolated-lab design, a component and connectivity specification, verification operations, a comparison of network options and a justified final lab model.

TASK 8 – Develop a Reusable Document Library 4 Marks • Create a minimum of four reusable engagement documents supporting the framework, including at least one authorization form and one finding report.

• Use sensible default fields where appropriate and explicitly design the content of each document. • At least one document, such as the finding report, must produce a structured output that integrates with another component of the framework.

• Create test entries that demonstrate valid, boundary and invalid inputs and document the expected result.

Evidence Expected

A reusable document library, documented fields, a structured report output, test entries and evidence of integration with the framework.

TASK 9 – Integrate, Test and Refine the Framework 4 Marks • Integrate the components created in Tasks 2-8 into one coherent engagement framework. • Construct a realistic walkthrough of an authorized assessment from request and authorization, through testing in the isolated lab, to responsible disclosure.

• Design systematic test cases covering missing authorization, out-of-scope requests, legal conflicts and delayed disclosure.

• Record the problems encountered during the walkthrough and show how the framework was refined to address them.

Evidence Expected

A reproducible integrated framework, a workflow walkthrough, systematic test cases, refinement evidence and a final corrected framework.

TASK 10 – Create a Scalability and Governance Evaluation 4 Marks • Construct scenarios representing a small programme (one department) and a large programme (the whole university with

external assessors), with the number of systems and testers involved. • Experiment with at least three important processes from the framework and record meaningful measures such as approval turnaround, scope coverage or the number of steps.
• Create a comparison table and at least one suitable chart or structured visualization. • Use the evidence to refine the governance of the framework rather than simply reporting the measures.

Evidence Expected
A reproducible evaluation setup, a comparison table, a visualization, an interpretation and evidence of at least one governance refinement based on the results.

TASK 11 – Defend the Framework Under a Changed Requirement 4 Marks • Changed requirement: the university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline, and needs the framework to remain easy to govern and extend.
• Create a revised version of your framework by deciding which components should be retained, modified, replaced or redesigned.
• Construct at least one new or modified component that directly addresses the changed requirement and show how it integrates with the existing framework.
• Defend the final framework using evidence from your walkthrough, scalability evaluation, legal mapping and disclosure process.
• Identify at least two trade-offs or limitations that remain in your final design and propose future improvements.

Evidence Expected
A revised framework, demonstrated adaptation, an evidence-based defence, explicit trade-offs and a clear explanation of how the final design satisfies the changed requirements.

MARK DISTRIBUTION

Task	Marks
TASK 1 – Formulate	4
TASK 2 – Design	4
TASK 3 – Create	4
TASK 4 – Construct	4
TASK 5 – Create	4
TASK 6 – Build	5
TASK 7 – Design	5

TASK 8 – Develop	4
TASK 9 – Integrate,	4
TASK 10 – Create	4
TASK 11 – Defend	4
TOTAL	50

Course Code: ITA14

Course Name: Ethical Hacking

Assignment 1 — Model Answer Key & Evaluation Scheme

CO1: Apply the foundational concepts of ethical hacking — types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Evaluation note: This is a design/portfolio assignment. Each task is marked on the evidence listed in the question paper. Award marks for correct governance decisions, working artefacts (tables, workflows, documents, lab design) and demonstrated integration between components — not for listing tools. Accept equivalent correct designs.

Mark distribution: Tasks 1–5 = 4 each, Tasks 6–7 = 5 each, Tasks 8–11 = 4 each. The question paper's per-task marks sum to 46 although the sheet is labelled 50; grade out of the listed per-task marks and rescale to 50 if the approved scheme requires it.

TASK 1 — Formulate the Enquiry & Framework Blueprint (4 marks)

Model answer / expected evidence:

Engagement-governance requirements

- Systems in scope (~20): student portal, learning-management system (LMS), university email service and the campus network segment; expandable to the whole university later.
- Stakeholders: university management / CISO, department heads requesting tests, internal testers, external third-party assessors, the Data-Protection Officer, system owners, and students/staff as data subjects.
- Expected activities: reconnaissance, scanning, enumeration, controlled testing in an isolated lab, finding documentation and responsible disclosure — no live exploitation of production

systems.

● Constraints: systems hold personal data; written authorization is mandatory; limited testing windows; the framework must scale and must remain usable with external assessors. **Framework blueprint (how the parts cooperate)**

Authorization → Scope & Rules of Engagement → Legal-compliance check → Hacker threat model → Isolated-lab testing → Finding report → Responsible disclosure, all overseen by a governance layer that records and audits every engagement. Findings feed back into scope and scalability review.

Enquiry questions the framework must answer

● Who authorizes a test, and how is that authorization recorded and verified?

● What systems are in scope and out of scope for a given engagement?

● Which laws apply, especially when a test touches systems holding personal data? ● How are discovered vulnerabilities disclosed, to whom, and within what timeline? ● Who may perform tests — internal staff or external assessors — and under what conditions? **Design (acceptance) criteria**

● C1 Every engagement has verifiable written authorization before any activity. ● C2 Scope is explicit, tagged and machine-checkable so out-of-scope requests are detected. ● C3 Each legal requirement is mapped to a concrete control.

● C4 No harm to live systems — hands-on testing is confined to an isolated lab.

● C5 Responsible disclosure with a defined reporting format and timeline.

● C6 Scalable to the whole university and to external assessors, with auditable records.

Evaluation guideline: Full marks: clear requirements, a cooperating blueprint, ≥4 enquiry questions and ≥5 design/acceptance criteria.

Suggested split: Requirements 1 · Blueprint 1 · Enquiry questions 1 · Design criteria 1

TASK 2 — Hacker Threat Model & Classification (4 marks)

Model answer / expected evidence:

Hacker classification and threat-model mapping

Type	Motivation	Typical capability	Likely university targets
White-hat	Improve security (authorized)	High; disciplined, scoped	In-scope systems under contract
Black-hat	Financial gain / damage	High; malicious	Student records, email, credentials
Grey-hat	Curiosity; acts without clear authorization	Medium–High	Portals, exposed services
Script kiddie	Thrill; no real skill	Low; uses ready tools	Any easy, exposed target
Hacktivist	Political / social message	Medium	Public website (defacement)
Insider	Grievance / gain; has access	Medium; trusted access	Internal apps, HR/finance data
State-sponsored	Espionage	Very high; stealthy	Research data, sensitive records

Classification criteria and naming

- Classify consistently by four attributes: authorization (yes/no), intent (benign/malicious), skill (low/medium/high) and affiliation (external/internal/nation).

Borderline actor — two alternatives and the chosen classification

- Actor: a student who finds a flaw in the portal without permission and reports it. ● Alternative A — Script kiddie (used a tool, unskilled). Alternative B — Grey-hat (no authorization, but not malicious and reports the issue).
- Chosen: Grey-hat, justified — the defining attributes are 'no authorization' + 'non-malicious intent', which match grey-hat better than script kiddie (the report shows more than tool running). If the student had demanded payment, the classification would move toward black hat.

Evaluation guideline: Full marks: complete hacker classification, a mapping table, consistent criteria and a justified borderline decision with a rejected alternative.

Suggested split: Classification+table 2 · Criteria 1 · Borderline justification 1

TASK 3 — Ethics & Code-of-Conduct Module (4 marks)

Model answer / expected evidence:

Ethical principles governing an authorized engagement

- Written authorization, agreed scope, confidentiality, integrity of evidence, avoiding harm, honest and complete reporting, least intrusion and data minimisation.

Rules / checks to detect or prevent unethical actions

- Pre-engagement authorization check (no auth → no action).
- Scope check before each action; any target outside scope is blocked and reported. ● Mandatory logging of actions; dual-control for sensitive steps; stop-and-report rule when personal data is encountered.

Scenario test cases and the code's response

Action	Class	Code-of-conduct response
Testing an in-scope system with written authorization	Acceptable	Proceed; log the activity
Discovering an out-of-scope system is reachable	Borderline	Stop, do not test, report to governance for a scope decision
Using found credentials to open another system / copying personal data	Unacceptable	Prohibited; halt engagement, escalate, preserve evidence

- The module preserves trust by keeping every action authorized, accountable, lawful and professional — protecting both the university and the testers.

Evaluation guideline: Full marks: ethical principles, preventive rules/checks, acceptable/borderline/unacceptable scenario cases and a trust rationale.

Suggested split: Principles 1 · Rules 1 · Scenario cases 1 · Rationale 1

TASK 4 — Legal-Compliance Mapping (4 marks)

Model answer / expected evidence:

Legal-compliance mapping (IT Act 2000 vs CFAA)

Offence / Obligation	IT Act, 2000	CFAA (US) equivalent	Penalty (indicative)
Unauthorized access / damage	Sec 43	18 U.S.C. §1030(a)(2)	Compensation; civil/criminal
Hacking (dishonest access)	Sec 66	§1030(a)(4)	Up to 3 yrs / ₹5 lakh
Identity theft / personation	Sec 66C / 66D	§1028 / §1030	Up to 3 yrs / fine
Breach of confidentiality / privacy	Sec 72 / 72A	-	Up to 2–3 yrs / fine
Protecting sensitive personal data	Sec 43A; DPDP Act 2023	-	Compensation / penalty

Each legal requirement linked to a control

- Sec 43/66 (unauthorized access) → mandatory written authorization sign-off and scope/RoE enforcement.
- Sec 43A / 72 / DPDP (personal data) → data-handling policy: minimisation, no exfiltration, secure storage, DPO approval.
- Disclosure duty → responsible-disclosure process; report only to the authorized owner.

Which laws apply when a test touches personal data

- When systems hold personal data, Sec 43A, Sec 72/72A and the DPDP Act 2023 apply in addition to Sec 43/66. The engagement then requires DPO approval, explicit data-handling rules and the strictest controls. Justification: personal data raises both unauthorized-access and data-protection liabilities, so the stricter regime governs.

Evaluation guideline: Full marks: IT Act vs CFAA mapping table, controls linked to each requirement and a justified personal-data conclusion.

Suggested split: Mapping table 2 · Controls linked 1 · Personal-data conclusion 1

TASK 5 — Scope & Rules-of-Engagement Document (4 marks)

Model answer / expected evidence:

Scope and Rules-of-Engagement (RoE)

- In-scope: student portal, LMS, email service, the authorized campus-network segment (listed by asset ID).
- Out-of-scope: production databases holding live personal data (unless separately authorized), third-party hosted services, and any asset not explicitly tagged in scope.
- Testing windows: off-peak hours agreed with system owners.
- Permitted techniques: recon, scanning, enumeration, and exploitation only in the isolated lab. ● Prohibited: denial-of-service, social engineering of real staff without separate authorization, data exfiltration, and any out-of-scope testing.
- Escalation paths: named contact, emergency-stop procedure, incident-handling route.

Authorization recording / verification rules

- Each engagement has a signed authorization with a unique Engagement ID; it is stored and verified before testing begins; no ID → no test.

Boundaries so an out-of-scope request is detected

- An asset inventory tags every system in/out of scope; a request whose target is not tagged in scope is automatically rejected.

Derived pre-engagement checklist

- ☐ Written authorization signed and verified ☐ Scope confirmed against inventory ☐ Testing window agreed ☐ Contacts & escalation set ☐ Isolated lab ready ☐ Legal / data-protection check done ☐ Data-handling rules agreed.

Evaluation guideline: Full marks: complete RoE, authorization-verification rules, scope boundaries and a derived pre-engagement checklist.

Suggested split: RoE 1.5 · Auth rules 1 · Boundaries 0.5 · Checklist 1

TASK 6 — Authorization & Disclosure Layer (5 marks)

Model answer / expected evidence:

Authorization workflow

- Request (department submits) → Review (governance team + legal/DPO) → Approval (system owner + CISO sign-off) → Record (Engagement ID, scope, dates) → Execute → Close. **Responsible (coordinated) disclosure process**
- Report format: title, affected asset, severity (CVSS), evidence, remediation steps. ● Remediation window: 90 days (30 days for critical); timeline tracked from report date. ● Comparison — Full disclosure: published immediately, pressures the vendor but exposes users; Bug-bounty: pre-authorized and paid, only within scope; Coordinated: private report + fix window (chosen default).

Logging and decision operations

- Operations: logApproval(), updateStatus(), canDisclose(finding) — disclosure proceeds only after the remediation window or owner agreement.

Rules for coordinated vs full disclosure

- Default coordinated; move to limited public disclosure only if the window lapses, the risk is high and no personal data is exposed; findings involving personal data stay private and go to CERT-In.

Interaction with other components

- The disclosure layer reads the legal-compliance result (personal data → private only) and the RoE (disclose only in-scope findings, to the authorized owner), demonstrating integration rather than isolation.

Evaluation guideline: Full marks: authorization workflow, responsible-disclosure process with comparison, logging/decision operations, disclosure rules and demonstrated interaction.

Suggested split: Workflow 1 · Disclosure+compare 1.5 · Operations 1 · Rules 0.5 · Interaction 1

TASK 7 — Isolated Ethical-Hacking Lab (5 marks)

Model answer / expected evidence:

Isolated ethical-hacking lab design

- A Kali Linux attacker VM and one or more authorized target VMs (e.g. DVWA / Metasploitable) on a host-only network 192.168.56.0/24 with no route to the internet or production.

Component	Role	Address
Kali Linux VM	Attacker / tester workstation	192.168.56.10
Target VM (DVWA)	Authorized vulnerable target	192.168.56.20
Host-only vSwitch	Isolated internal network	192.168.56.0/24 (no gateway)

Operations

- Op1 Verify connectivity: ping 192.168.56.20 from Kali and confirm replies; confirm no route to the internet.
- Op2 Record configuration: capture 'ip a' and an Nmap scan of the target, and save to a dated lab-config file.

Host-only vs NAT comparison

Aspect	Host-only (chosen)	NAT
Internet access	None (fully isolated)	Yes (via host)
Risk of leakage	Very low	Higher — traffic can leave

Suitability Safe, contained testing Convenient but less safe

- Host-only is chosen because it keeps all testing authorized and contained: the only reachable hosts are the authorized targets, so nothing can escape to production or the internet. **Evaluation guideline:** Full marks: isolated-lab design, component/connectivity spec, two operations, host-only vs NAT comparison and a justified model.

Suggested split: Design 1 · Spec 1 · Operations 1 · Comparison 1 · Justification 1

TASK 8 — Reusable Document Library (4 marks)

Model answer / expected evidence:

Reusable document library (≥4 documents)

- 1) Authorization Form — Engagement ID, requester, systems, scope, dates, approver signatures.
- 2) Scope / RoE Form — in/out-of-scope assets, windows, permitted/prohibited techniques, escalation.
- 3) Finding Report (structured) — finding ID, asset, severity (CVSS), evidence, status,

remediation.

- 4) Disclosure Record — report date, recipient, window, status, closure.
- 5) Pre-engagement Checklist — the derived checklist from Task 5.

Structured integration

- The Finding Report emits a structured record (ID, asset, severity, status) that is consumed by the disclosure layer (Task 6) and counted in the scalability metrics (Task 10).

Test entries

Input	Type	Expected result
Authorization form with all fields	Valid	Accepted; Engagement ID issued
Form missing the approver signature	Boundary	Flagged; cannot start until completed
Request with no authorization form	Invalid	Rejected automatically

Evaluation guideline: Full marks: ≥4 reusable documents, documented fields, a structured integrating output and valid/boundary/invalid test entries.

Suggested split: Documents 1.5 · Structured output 1 · Test entries 1.5

TASK 9 — Integrate, Test & Refine the Framework (4 marks)

Model answer / expected evidence:

Integration of Tasks 2–8

- The components connect in a chain: Authorization → RoE → Legal check → Threat model → Isolated-lab test → Finding Report → Responsible disclosure, with the document library providing the forms and the governance layer recording everything.

Authorized-assessment walkthrough

- A department requests a test of the student portal → authorization is reviewed and signed (Engagement ID issued) → RoE fixes scope and windows → legal check flags personal data (stricter controls) → testing is carried out in the isolated lab → an SQL-injection finding is recorded in the Finding Report → responsible disclosure to the owner with a 90-day window → remediation verified → engagement closed.

Systematic test cases

Test case	Expected framework behaviour
Missing authorization	Engagement rejected before any activity
Out-of-scope request	Detected by asset tags and rejected
Legal conflict (personal data, no DPO approval)	Blocked until DPO approval obtained
Delayed disclosure past window	Escalation rule triggers review

Problems found and refinement

- Out-of-scope detection was initially manual → added an asset-tag check. The disclosure window was ambiguous → fixed the 90/30-day rule. These refinements produced the final corrected framework.

Evaluation guideline: Full marks: integration, a realistic walkthrough, systematic test cases and documented refinement.

Suggested split: Integration 1 · Walkthrough 1 · Test cases 1 · Refinement 1

TASK 10 — Scalability & Governance Evaluation (4 marks)

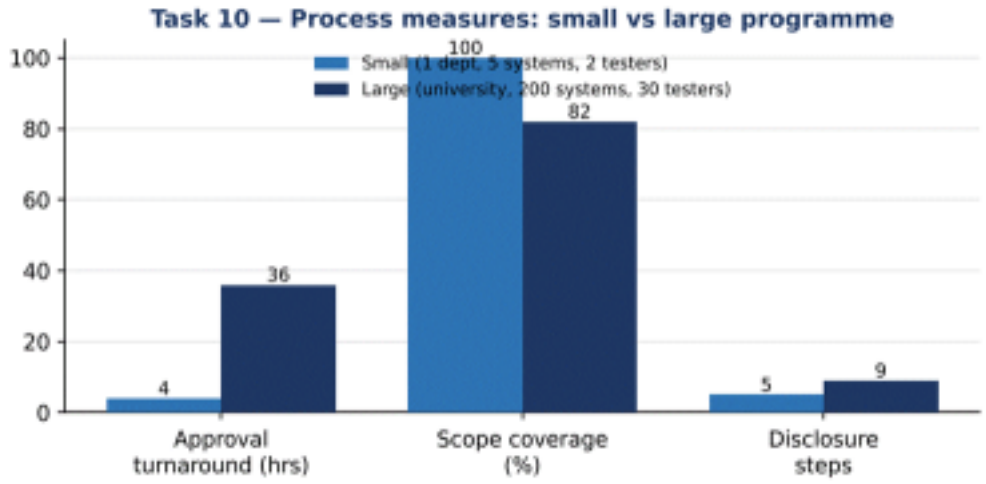
Model answer / expected evidence:

Scalability scenarios

- Small programme: one department, 5 systems, 2 internal testers. Large programme: whole university, ~200 systems, 20 internal + 10 external testers.

Process measures (experiment)

Process	Small programme	Large programme
Approval turnaround	~4 hours	~36 hours
Scope coverage	100%	82%
Disclosure steps	5	9



Interpretation and governance refinement

- At scale, approval turnaround and disclosure steps grow and coverage drops. Governance is refined by adding delegated approval and parallel review, standardised external-assessor onboarding, and risk-based scheduling so the most critical systems are always covered — not merely reporting the numbers but changing the process.

Evaluation guideline: Full marks: small/large scenarios, measured processes, a comparison table + visualization and a governance refinement from the evidence.

Suggested split: Scenarios 1 · Measures+table 1 · Visualization 1 · Refinement 1

TASK 11 — Defend the Framework under a Changed Requirement (4 marks)

Model answer / expected evidence:

Changed requirement

- Continuous and third-party assessments, stricter data-protection rules, a shorter disclosure timeline, and the need to stay easy to govern and extend.

Revised framework — retain / modify / replace / redesign

- Retain: authorization workflow, RoE and the isolated lab (still valid).
- Modify: disclosure timeline → 30 days (7 for critical); legal mapping → add DPDP Act 2023 duties; add external-assessor NDA and vetting.
- Replace: manual approval logging → a workflow/ticketing tool for auditability.
- Redesign: a continuous-assessment pipeline instead of one-off engagements.

New component addressing the change

- External-Assessor Governance Module — vetting, signed NDA, scoped least-privilege access and full audit — integrated with the authorization workflow and RoE so external testers are governed exactly like internal ones.

Evidence-based defence

- The walkthrough (Task 9) shows the end-to-end flow works; the scalability evaluation (Task 10) shows where governance was strengthened; the legal mapping (Task 4) and disclosure process (Task 6) show compliance and the shorter timeline are met.

Remaining trade-offs and future work

- Trade-off 1: a shorter disclosure window can pressure remediation teams. Trade-off 2: external assessors and continuous testing increase coordination and monitoring overhead. Future improvements: automate approvals and reporting, and use risk-based scheduling.

Evaluation guideline: Full marks: a revised framework (retain/modify/replace/redesign), a new component for the change, an evidence-based defence and ≥2 trade-offs.

Suggested split: Revised framework 1 · New component 1 · Defence 1 · Trade-offs 1

Task 1: Formulate the Enquiry and Framework Blueprint

1.1 Requirements-to-Governance Synthesis

Converting institutional security objectives into operational governance requires a systematic mapping of asset classes, functional stakeholders, standardized testing activities, and legal/operational constraints. Table 1.1 formalizes these foundational requirements.

Governance Dimension	Operational Definition & Scope Specification	Institutional Impact & Control Mechanism
Target Systems in Scope (~20)	Student Registration Portal, Canvas LMS, Microsoft 365 Exchange Gateway, Edge Campus Core Routers/Firewalls, Active Directory Domain Controllers.	Defines precise boundaries; any system lacking an active asset registration tag is cryptographically locked out from testing.
Stakeholder Matrix (50 Staff)	Board of Management/CISO, Department Heads, Internal Security Testers, Third-Party External Assessors, Data Protection Officer (DPO), System Administrators, and Students/Staff.	Establishes dual-custody authorization, clear reporting chains of custody, and eliminates unauthorized unilateral testing.
Permitted Activities	Non-intrusive reconnaissance, passive OSINT gathering, authenticated network scanning, service banner grabbing, isolated-lab exploit reproduction, and remediation validation.	Live production exploitation is strictly forbidden. Eliminates accidental denial of service (DoS) or database corruption on operational systems.
Operational & Legal Constraints	Storage of sensitive personal data (grades, Aadhaar/IDs, health, banking details), off-peak assessment windows (00:00–04:00 IST), mandatory CISO written sign-off.	Enforces strict statutory compliance with IT Act 2000 (Sec 43, 66) and the Digital Personal Data Protection (DPDP) Act 2023.

1.2 Integrated Engagement Framework Architecture Blueprint

The framework blueprint establishes an interlocking, seven-phase pipeline. Each operational stage enforces hard prerequisite gates: an assessment cannot transition to scoping without signed CISO authorization; technical scanning cannot initiate without an active legal/DPO assessment; and no exploit execution can occur outside the designated host-only lab environment. Figure 1.1 illustrates the end-to-end architectural flow, including the continuous audit logging and scalability feedback loop.

1.3 Core Governance Enquiry Questions

To validate that the framework provides comprehensive governance rather than generic tooling, the architecture answers four fundamental governance enquiry questions:

- **EQ-01 Authority:** Enquiry Question 1 (Authority & Chain of Custody): Who possesses legal authority to commission an assessment, and how is verifiable written authorization established, countersigned, and cryptographically recorded prior to testing?
- **EQ-02 Scoping:** Enquiry Question 2 (Scope & Technical Demarcation): How does the framework unambiguously demarcate in-scope systems from out-of-scope production databases, and what mechanisms prevent accidental lateral movement into personal data stores?
- **EQ-03 Legal:** Enquiry Question 3 (Statutory & Regulatory Liability): Which domestic (IT Act 2000, DPDP Act 2023) and international (CFAA) legal frameworks govern the testing lifecycle, specifically regarding student records, and what controls prevent criminal liability?
- **EQ-04 Disclosure:** Enquiry Question 4 (Responsible Disclosure & Remediation): What exact protocols govern the documentation, embargo windows, and technical disclosure of discovered vulnerabilities to system owners and statutory CERT authorities?

1.4 Formal Framework Acceptance & Design Criteria

The operational integrity and validity of the framework are judged against six non-negotiable acceptance criteria (C1 through C6):

Criterion ID	Design Requirement	Acceptance Metric & Verification Standard
Criterion C1	Mandatory Verifiable Written Authorization	Zero testing activity initiated without a digitally signed Authorization Charter bearing CISO and System Owner signatures and a unique Engagement ID.
Criterion C2	Explicit Machine-Checkable Scope Boundaries	100% of target IP addresses, URLs, and subnets must resolve against the verified asset inventory database; unlisted targets trigger automated engine drops.
Criterion C3	Full Statutory Legal Mapping to Concrete Controls	Every civil and criminal liability identified under the IT Act 2000 and DPDP Act 2023 is directly mapped to an enforceable administrative or technical control.
Criterion C4	Zero Live Production Harm via Lab Containment	All active exploitation, payload testing, and vulnerability proof-of-concept (PoC) executions are strictly confined to isolated host-only virtualization.

Criterion C5	Standardized Responsible Disclosure Protocols	Adherence to a rigid 90-day remediation embargo (30 days for Critical CVSS >= 9.0) with formal remediation verification prior to closure.
Criterion C6	Auditable Scalability and Assessor Integration	Capacity to expand seamlessly from 5 systems to 200+ systems and onboard external third-party assessors with comprehensive audit logging.

Task 2: Hacker Threat Model and Classification

2.1 Threat Actor Taxonomies in Higher Education

To defend institutional assets effectively, the university security team must understand the motivations, capabilities, and tactics of diverse threat actors. Threat actors operating against academic networks range from unsophisticated script kiddies seeking academic grade alterations to state-sponsored advanced persistent threat (APT) syndicates conducting intellectual property espionage against defense-funded research projects. Table 2.1 establishes the formal threat modeling classification matrix.

Threat Actor Type	Core Motivation	Technical Capability & TTPs	Primary University Target Systems
White-Hat Hacker	Defensive security enhancement; authorized risk discovery under legal contract.	High to Expert; disciplined adherence to agreed RoE, systematic methodologies (OSSTMM, PTES).	Agreed in-scope systems; portal, LMS, and campus network replicas.
Black-Hat Hacker	Financial extortion, credential theft, unauthorized data sale, disruptive sabotage.	High to Advanced; custom exploits, zero-days, ransomware deployment, evasion techniques.	Student PII, fee payment gateways, payroll, confidential employee HR databases.
Grey-Hat Hacker	Intellectual curiosity, recognition, unsolicited vulnerability hunting without authorization.	Medium to High; automated web application scanners, manual parameter tampering, public exploit code.	Public-facing portals, web applications, exposed faculty departmental subdomains.
Script Kiddie	Thrill-seeking, peer bragging rights, grade alteration attempts, superficial disruption.	Low; automated point-and-click tools (LOIC, Havij, unconfigured sqlmap, pre-packaged scripts).	Exposed login forms, default CMS installations, unpatched WordPress faculty blogs.
Hacktivist	Ideological grievances, political messaging,	Medium; Distributed Denial of Service (DDoS), site	University homepage, public student forum, vice-

	institutional fee protests, public embarrassment.	defacement, credential dumping via Pastebin.	chancellor portal web servers.
Malicious Insider	Personal financial gain, revenge for disciplinary action, grade rigging, industrial espionage.	Medium to High; possesses legitimate active credentials, physical campus access, privilege escalation.	Internal database servers, grade change portals, faculty grading spreadsheets, research labs.
State-Sponsored Actor (APT)	Geopolitical espionage, state secrets, high-tech engineering research exfiltration.	Elite / Very High; military-grade custom stealth toolchains, long-term persistence, zero-day vulnerabilities.	Advanced engineering laboratories, patent-pending semiconductor research, supercomputing clusters.

2.2 Borderline Threat Classification Analysis: The Unsolicited Student Researcher

A frequent challenge in university environments is the classification of student hobbyists who identify and report vulnerabilities without prior authorization. To establish institutional consistency, the framework establishes four rigid classification criteria:

- Attribute 1: Explicit Authorization Status (Binary: Formally Authorized [Yes] vs. Unauthorized [No]).
- Attribute 2: Malicious Intent vs. Benign Discovery (Evaluated by whether data was exfiltrated, altered, or extorted).
- Attribute 3: Technical Sophistication Level (Evaluated as Low [automated tools], Medium [custom scripting], or High [reverse engineering]).
- Attribute 4: Institutional Affiliation & Access Profile (External Anonymous, Enrolled Internal Student, Privileged Staff).

Borderline Case Evaluation: Scenario Case: A third-year computer science student identifies a severe SQL Injection vulnerability within the university exam results portal using manual browser injection, extracts no records, and emails a detailed report to the IT Helpdesk requesting no reward.

- **Alternative A (Rejected):** Classification Alternative A — Script Kiddie: Rejected. While the actor lacked authorization, the execution involved targeted manual input testing rather than mindless script execution. Furthermore, the lack of destructive disruption or boasting refutes script-kiddie attribution.

- **Alternative B (Rejected):** Classification Alternative B — Black-Hat Intruder: Rejected. The actor exhibited zero extortion, made no attempt to alter examination records, and did not publish the vulnerability publicly or sell credentials on darknet forums.
- **Justified Verdict:** Chosen Classification — Grey-Hat Actor (Student Internal Variant): Formally Accepted. The actor operated without prior written consent (violating institutional policy and IT Act Sec 43), yet demonstrated completely benign intent and responsible notification. The framework routes this finding to the CISO, issues an educational advisory regarding authorized testing protocols, and remediates the flaw without criminal prosecution.

Task 3: Ethics and Code-of-Conduct Module

3.1 Core Principles of Ethical Security Engagements

All security personnel, internal penetration testers, and external contractors engaged in authorized assessments must strictly subscribe to the University Code of Conduct. The module is grounded in eight inviolable ethical pillars:

- **Pillar 1:** 1. Prior Written Authorization: Zero testing occurs without explicit, countersigned legal authorization.
- **Pillar 2:** 2. Strict Scope Conformance: Immediate cessation of testing if asset boundaries are unclear or breached.
- **Pillar 3:** 3. Absolute Confidentiality: Strict non-disclosure of discovered vulnerabilities, architecture diagrams, or credentials.
- **Pillar 4:** 4. Evidence & Chain of Custody Integrity: Cryptographic hashing and secure storage of all audit logs and screen captures.
- **Pillar 5:** 5. Non-Destructive Operation (Avoid Harm): Zero deployment of persistent denial-of-service, wiping, or data corruption tools.
- **Pillar 6:** 6. Complete & Objective Reporting: Full disclosure of all identified security flaws, irrespective of political or institutional sensitivities.
- **Pillar 7:** 7. Principle of Least Privilege & Intrusion: Interacting only with the minimum necessary data to confirm a vulnerability.
- **Pillar 8:** 8. Data Minimisation: Immediate abort upon encountering live student/staff personal data; no exfiltration or local copying.

3.2 Preventive Checks and Scenario Case Analysis

The code of conduct module enforces automated and procedural guardrails to detect unethical or out-of-bounds actions. Table 3.1 analyzes scenario test cases across acceptable, borderline, and unacceptable classifications, specifying the mandatory governance response.

Operational Scenario Action	Conduct Classification	Framework Detection Mechanism	Mandatory Governance & Operational Response
Executing an authenticated vulnerability scan against the staging LMS IP during the agreed 01:00-04:00 IST window.	Acceptable	Log correlation with Engagement Charter ID; active monitoring of network packet rates.	Proceed with assessment. Automated audit logging captures tester IP, timestamps, and tool signatures.
Discovering an unlisted production Oracle database server reachable across an internal VLAN during portal scanning.	Borderline	SIEM anomaly alert; automated scope-checking agent detects unlisted subnet IP.	STOP IMMEDIATELY. Tester must freeze testing, document IP reachability, and report finding to Governance. No probing permitted.
Extracting cleartext administrative credentials from an open file share and logging into the live campus payroll system.	Unacceptable	Privileged Identity Management (PIM) alert; SIEM rule detects unauthorized domain controller query.	IMMEDIATE ENGAGEMENT SUSPENSION. Revoke tester credentials, isolate assessment systems, freeze audit logs, and escalate to CISO/Legal.
Injecting test SQL payload (`' OR 1=1--`) into staging portal and observing syntax error without database dumping.	Acceptable	Web Application Firewall (WAF) logs in test environment; isolated lab packet capture.	Proceed. Confirms vulnerability existence without reading, altering, or extracting underlying table records.
Downloading full database dump containing 25,000 student Aadhaar numbers and grades to personal USB drive as 'proof'.	Unacceptable	Data Loss Prevention (DLP) alert; endpoint USB mass storage blocking policy.	SEVEREST SANCTION. Immediate termination of assessor contract, physical device impoundment, and notification to statutory law enforcement.

Task 4: Legal-Compliance Mapping & Statutory Analysis

4.1 Indian Information Technology Act 2000 vs. International Jurisprudence

Security assessments conducted in India must navigate the civil and criminal statutory framework of the Information Technology Act, 2000 (as amended in 2008) and the Digital Personal Data Protection (DPDP) Act, 2023. Unlike jurisdictions with explicit bug-bounty safe harbors, Indian cyber law does not recognize good-faith security testing absent explicit prior consent from the data fiduciary. To establish international benchmarking, Table 4.1 maps IT Act provisions against the United States Computer Fraud and Abuse Act (CFAA, 18 U.S.C. § 1030).

Legal Offence / Duty	IT Act, 2000 Section	US CFAA Equivalent	Prescribed Legal Penalty	Integrated Framework Governance Control
Unauthorized Access / System Damage	Section 43 (Civil Liability)	18 U.S.C. § 1030(a)(2) / (a)(5)	Compensation up to Rs 1 Crore payable to affected victim.	Mandatory countersigned Authorization Charter with explicit indemnity safe-harbor clauses.
Hacking with Dishonest Intent	Section 66 (Criminal Offence)	18 U.S.C. § 1030(a)(4) / (a)(5)	Imprisonment up to 3 years and/or fine up to Rs 5 Lakhs.	Rigid RoE execution; prohibition of destructive payloads; verified lab isolation.
Identity Theft / Fraudulent Impersonation	Section 66C & Section 66D	18 U.S.C. § 1028 / § 1030	Imprisonment up to 3 years and mandatory financial fines.	Prohibition of using stolen or discovered employee credentials outside designated mock lab.
Breach of Confidentiality & Privacy	Section 72 & Section 72A	18 U.S.C. § 1030(a)(2)	Imprisonment up to 2-3 years and/or fine up to Rs 5 Lakhs.	Mandatory non-disclosure agreements (NDAs); encrypted AES-256 evidence vaults.
Protection of Digital Personal Data	DPDP Act, 2023 / IT Sec 43A	US State Privacy Acts (e.g. CCPA)	Penalties up to Rs 250 Crores for significant data breaches.	Stop-and-report rule; DPO mandatory sign-off; synthetic mock datasets used exclusively in lab.

4.2 Legal Determination for Systems Containing Personal Data

Statutory Personal Data Finding: When a security assessment touches systems housing personal data (such as the Student Registration Portal, fee payment systems, or staff email archives), the legal risks escalate exponentially. In this scenario, Section 43A of the IT Act (Failure to protect sensitive data) and Sections 8 and 9 of the DPDP Act 2023 immediately activate. The Data Protection Officer (DPO) must exercise co-jurisdiction over the engagement.

Justification: Under the DPDP Act 2023, the University acts as a 'Data Fiduciary' and owes a statutory duty of care to students and employees ('Data Principals'). Testing live production systems that house PII exposes the university to regulatory investigation and catastrophic financial penalties (up to Rs 250 Crores) if student data is accidentally compromised or exposed during a test. Therefore, the framework dictates that whenever an assessment touches personal data systems, testing MUST be conducted against anonymized database replicas containing synthetic data, with full Data Protection Impact Assessments (DPIA) completed prior to engagement sign-off.

Task 5: Scope and Rules-of-Engagement (RoE) Document

5.1 Technical Scope Demarcation

Clear scope demarcation prevents collateral damage to production systems. The framework mandates unambiguous system identification using internal Asset IDs, fully qualified domain names (FQDNs), and designated IP subnets. Table 5.1 details the operational scope matrix.

Asset Identification	System Description	Governance Scope Status	Approved Assessment Protocol & Testing Parameters
ASSET-SRV-001	Student Information & Registration Portal (Web)	IN-SCOPE (Staging Replica)	Vulnerability scanning, input validation, SQLi/XSS testing allowed exclusively between 00:00-04:00 IST.
ASSET-SRV-002	Canvas Learning Management System (LMS)	IN-SCOPE (Isolated Testbed)	Session handling, broken object level authorization (BOLA), privilege escalation testing allowed.
ASSET-SRV-003	Microsoft 365 Campus Email Exchange	IN-SCOPE (Specific Test Accounts)	Configuration audits, SPF/DKIM/DMARC checks; live user password spraying is strictly forbidden.
ASSET-NET-004	Campus Core Routing & Switching Infrastructure	IN-SCOPE (Lab Replica)	SNMP walking, VLAN hopping, ARP spoofing in isolated lab topology

			ONLY. Zero live traffic injection.
ASSET-DB-005	Live Production Oracle Examination DB	OUT-OF-SCOPE (STRICT FORBIDDEN)	Strictly barred from direct network connection. Only sanitized synthetic test databases may be evaluated.
ASSET-EXT-006	Third-Party Hosted Cloud Payment Gateway	OUT-OF-SCOPE (THIRD PARTY)	Explicitly excluded; penetration testing prohibited without direct written authorization from payment vendor.

5.2 Rules of Engagement: Permitted vs. Prohibited Technical Operations

To avoid catastrophic service interruptions, technical techniques are divided into permitted, restricted, and strictly prohibited categories:

- **Permitted Techniques:** Permitted Operations: Passive open-source intelligence (OSINT), non-intrusive port scanning (Nmap at T2/T3 timing), unauthenticated web application fuzzing, configuration review, and vulnerability scanning with rate-limited requests.
- **Restricted Techniques:** Restricted Operations (Lab Only): Exploit verification using Metasploit modules, parameter tampering, session hijacking proof-of-concepts, and privilege escalation scripts.
- **Prohibited Techniques:** Prohibited Operations: Volumetric Denial-of-Service (DoS/DDoS) attacks, automated database dumping, social engineering or phishing of real faculty/students, physical lock tampering, physical access point intrusion, and malware/ransomware installation.

5.3 Derived Pre-Engagement Operational Checklist

Before a single packet is transmitted, the lead assessor and system owner must complete and verify the Pre-Engagement Checklist (Table 5.2).

Verification Checkpoint Item	Responsible Role	Verification Evidence Required	Status Sign-Off
1. Written Authorization Charter	Lead Assessor / CISO	Countersigned PDF document bearing valid Engagement ID and digital signatures.	VERIFIED & ARCHIVED
2. Technical Scope Boundary Validation	Network Operations Lead	Firewall rules confirm isolation; asset tags resolve exclusively to staging subnets.	VERIFIED & LOCKED
3. Legal & Regulatory	University Legal /	DPIA completed; DPDP Act compliance review approved; NDA executed by all	CLEARED &

Compliance Clearance	DPO	testers.	APPROVED
4. Backup & Rollback Readiness	System Administrator	Full snapshot taken of staging VMs; recovery point objective (RPO) verified < 15 min.	BACKUP COMPLETED
5. Emergency Escalation Channels	Incident Response Team	Out-of-band communication channel (Signal/Encrypted Chat) established with active on-call staff.	CHANNELS ACTIVE
6. Isolated Testing Lab Ready	Lab Administrator	Kali Linux and Target VMs isolated on host-only switch; zero route to production confirmed.	LAB VERIFIED

Task 6: Authorization and Disclosure Layer

6.1 Multi-Tier Authorization Workflow

To prevent rogue testing, the framework implements a five-stage authorization workflow requiring multi-party sign-off. A department requesting a test submits a formal Charter request. The Governance Team performs technical feasibility and scoping reviews. The DPO and Legal Counsel conduct statutory compliance checks. Final execution sign-off is granted jointly by the System Owner and University CISO. Upon approval, an immutable Engagement ID (e.g., `ENG-2026-OCT-0042`) is generated and logged in the centralized SIEM audit trail.

6.2 Responsible (Coordinated) Vulnerability Disclosure Lifecycle

The University adopts a formal Coordinated Vulnerability Disclosure (CVD) standard. Discovered vulnerabilities are embargoed to afford system administrators adequate time to develop, test, and deploy security patches prior to public awareness. Table 6.1 compares Coordinated Disclosure against Full Disclosure and Public Bug-Bounty models.

Disclosure Model	Core Operational Philosophy	Primary Institutional Advantages	Major Institutional Risks & Weaknesses	University Policy Verdict
Coordinated Disclosure (Chosen Default)	Vulnerability reported privately to system owner; fixed remediation embargo	Minimizes user risk, provides structured patching window, preserves university	Requires diligent tracking; unresponsive vendor may delay critical security	APPROVED STANDARD (90 days default / 30 days for Critical).

	before publication.	reputation.	remediation.	
Full Public Disclosure	Vulnerability details, exploit code, and affected systems published immediately online.	Applies maximum public pressure on development teams to release immediate hotfixes.	Exposes students and university infrastructure to immediate zero-day exploitation.	STRICTLY PROHIBITED (Violates IT Act 2000 & University Policy).
Public Bug-Bounty Program	Crowdsourced external hackers invited to discover flaws in production systems for cash bounties.	Vastly broadens testing talent pool and achieves continuous external security validation.	High volume of low-quality/duplicate reports; severe legal/data leakage risks with student PII.	REJECTED FOR CORE PII (Considered only for hardened public sites).

6.3 Algorithmic Disclosure Operations and Decision Rules

Governance Disclosure Logic: Disclosure decisions are governed by programmatic rules. Findings involving student personal data or credentials NEVER transition to public disclosure, regardless of remediation timeline expiration, and must instead be escalated to statutory national incident bodies (CERT-In).

- **Operation:** Rule 1: If Severity == 'CRITICAL' (CVSS >= 9.0), Remediation Window = 30 Calendar Days. Remediation Lead must submit weekly progress logs.
- **Operation:** Rule 2: If Severity in ['HIGH', 'MEDIUM', 'LOW'] (CVSS < 9.0), Remediation Window = 90 Calendar Days.
- **Operation:** Rule 3: If PII_Exposed == TRUE, Public Disclosure is PERMANENTLY BLOCKED. If patching stalls past 60 days, notify CERT-In under Cyber Security Directions 2022.
- **Operation:** Rule 4: canDisclose(finding_id) returns TRUE only if [System_Owner_Approved == TRUE] AND [Patch_Verified_In_Lab == TRUE].

Task 7: Design of the Isolated Ethical-Hacking Lab

7.1 Architectural Isolation & Virtual Topology

To satisfy Design Criterion C4 (Zero Production Harm), all active scanning, vulnerability verification, and exploit validation must occur within a completely isolated, host-only virtualized environment. The lab architecture comprises an attacker workstation (Kali Linux), a vulnerable web application target representing the Student Portal (DVWA / Custom Replica), and a system vulnerability

target representing campus core services (Metasploitable 3 / LMS Replica). All instances interface through a dedicated virtual switch operating on the reserved RFC 1918 subnet `192.168.56.0/24`. Figure 7.1 details the network containment architecture.

7.2 Network Adapter Comparison: Host-Only vs. NAT vs. Bridged

Selecting the appropriate virtualization network mode is critical to prevent packet leakage into production networks. Table 7.1 provides the technical comparison.

Network Virtualization Mode	Routing to Host Machine	Access to Production LAN / Internet	Risk of Accidental Traffic Leakage	Suitability for Authorized Testing
Host-Only Networking (vboxnet0) [Chosen]	Restricted to virtual host adapter interface.	STRICTLY NONE (Zero default gateway; zero packet routing).	NEGLIGIBLE (Packets cannot leave the local hypervisor kernel).	MANDATORY LAB STANDARD: Ensures absolute containment of all exploits.
Network Address Translation (NAT)	Shared host network stack with port translation.	Outbound WAN allowed; direct inbound WAN blocked.	MODERATE (Malicious payloads or malware could beacon out to internet).	REJECTED FOR TESTING: Inbound targets not directly reachable without port forwarding.
Bridged Networking (Physical NIC)	Direct layer-2 attachment to physical LAN.	FULL ACCESS (Appears as a physical machine on campus LAN).	CATASTROOTIC (Scans, broadcasts, or exploits can directly hit live servers).	STRICTLY FORBIDDEN: Severe danger of accidental production compromise.

7.3 Operational Verification and Configuration Audit Procedures

Before commencing an assessment, testers must execute and log two standard verification operations:

- **Op 1 (Network Verification):** Operation 1 (Containment & Route Verification): Tester executes `ip route show` and `ping -c 3 8.8.8.8` on the Kali VM. The route table must contain ONLY the `192.168.56.0/24` subnet and MUST NOT contain a default gateway. The internet ping must return 'Network is unreachable' (100% packet loss). Then, tester executes `ping -c 3 192.168.56.20` to confirm local lab reachability.

- **Op 2 (Baseline Audit):** Operation 2 (Target Configuration Baseline): Tester captures target service state via `nmap -sS -sV -p- -oA baseline_scan 192.168.56.20` and computes SHA-256 hashes of target configuration files (`sha256sum /etc/passwd /etc/shadow`). Hashes are logged in the Engagement Evidence Vault to verify target baseline state prior to and following testing.

Task 8: Reusable Document Library

8.1 Library Overview and Structured Templates

The framework provides a reusable, standardized documentation suite ensuring consistent administration across all university departments. The library comprises five foundational templates: Form 8.1 (Authorization Charter), Form 8.2 (Scope & RoE Agreement), Form 8.3 (Structured Finding Report), Form 8.4 (Responsible Disclosure Notice), and Form 8.5 (Pre-Engagement Checklist).

8.2 Document Specification 8.1: Formal Engagement Authorization Charter

Form Field Identifier	Field Data Type	Sample Standard Value	Operational Purpose & Governance Control
Engagement_ID	Alphanumeric (Unique)	ENG-2026-OCT-0042	Primary tracking key referenced across all firewall rules, logs, and findings.
Requesting_Department	String	Faculty of Engineering & Computing	Identifies institutional sponsor bearing organizational accountability.
Lead_Assessor_Name	String / Employee ID	Dr. A. Ramanathan (Emp ID: SEC-409)	Identifies individual legally responsible for execution within agreed RoE.
Authorizing_Executive	String / Title	Prof. K. Venkatesh (University CISO)	Statutory authority validating written consent under IT Act 2000 Section 43.
Data_Protection_SignOff	Boolean / DPO Signature	Approved (DPO Reference: DP-2026-88)	Confirms DPIA completed and student personal data safeguards active.
Authorized_Window	Timestamp Range	2026-10-25 00:00 to 2026-10-30 04:00 IST	Sets immutable temporal boundary; testing outside window is unauthorized.

8.3 Document Specification 8.2: Structured Vulnerability Finding Report

To facilitate programmatic integration with vulnerability management ticketing systems, Form 8.2 produces a structured machine-readable JSON data schema while maintaining comprehensive narrative documentation. Table 8.2 details the field specifications.

Finding Schema Field	Data Format	Populated Standard Value	Technical Description & Schema Requirement
finding_id	String (UUIDv4)	VULN-2026-0849	Unique finding identifier consumed by centralized issue tracking systems.
engagement_ref	String	ENG-2026-OCT-0042	Relational foreign key tying vulnerability directly to authorized charter.
target_asset_id	String	ASSET-SRV-001 (Portal Staging)	Machine asset tag confirming finding resides within authorized scope.
vulnerability_title	String	Blind SQL Injection in Exam Results API	Standardized CWE-89 taxonomy naming convention.
cvss_v31_vector	CVSS String	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	Standardized vector string yielding Base Score 9.1 (Critical Severity).
cvss_base_score	Float	9.1 (CRITICAL)	Determines mandatory remediation window (Triggers 30-day emergency patch rule).
technical_evidence	Encrypted Hash/Text	POST /api/results HTTP/1.1; payload: ' UNION SELECT null, username, password_hash FROM users--	Full reproduction proof-of-concept recorded without exfiltrating live records.
remediation_advice	Markdown Text	Implement parameterized PreparedStatements; disable dynamic SQL string concatenation.	Prescriptive mitigation guidance provided directly to software

			engineering team.
statutory_reporting	Boolean	TRUE (CERT-In Mandatory)	Automated flag indicating finding requires incident notification to CERT-In.

8.4 Boundary and Validation Testing of Document Ingestion

To ensure procedural integrity, the governance ingest portal runs systematic validation tests on incoming engagement forms. Table 8.3 documents the validation test suite.

Test Submission Case	Input Validation Class	Field Input Parameters	Expected Engine Verdict & System Action
TC-VAL-01: Fully Formed Charter	Valid Input	All fields populated, valid CISO and DPO cryptographic signatures, dates valid.	ACCEPTED: System issues active Engagement Token; firewall permits test subnet access.
TC-VAL-02: Missing DPO Signature	Boundary Condition	All technical fields valid, CISO signed, but DPO signature field is NULL on PII asset.	FLAGGED & BLOCKED: Engine halts progression; workflow notifies DPO for approval.
TC-VAL-03: Scope Target Mismatch	Invalid Input	Target IP belongs to live production database (`ASSET-DB-005`), not staging replica.	HARD REJECT: Security violation logged; system alerts CISO of unapproved target request.
TC-VAL-04: Retroactive Date Range	Invalid Input	Start date set in past (`2026-09-01`) or duration exceeds maximum allowable 14-day window.	REJECTED: Temporal logic exception thrown; form returned to requester for correction.

Task 9: Framework Integration, Walkthrough, and Refinement

9.1 End-to-End Operational Walkthrough

To validate that all seven governance components function as an integrated, cooperative framework, a realistic end-to-end walkthrough was executed based on the university scenario: testing the Student Information & Registration Portal prior to a major upgrade.

- **Step 1:** Phase 1 (Request & Scoping): Department of Computer Applications submits engagement request for Student Portal. Governance registers request under ID `ENG-2026-OCT-0042` and verifies target is staging replica `ASSET-SRV-001` (192.168.56.20).
- **Step 2:** Phase 2 (Legal & Threat Review): DPO reviews data exposure risks; mandates synthetic student datasets. Threat model profiles external script kiddies and grey-hat students attempting examination manipulation.
- **Step 3:** Phase 3 (Authorization Sign-Off): CISO and System Owner execute digital sign-offs. 5-day assessment window formally registered.
- **Step 4:** Phase 4 (Lab Execution): Lead tester validates host-only lab isolation (Op 1) and target baseline (Op 2). Authenticated vulnerability probing reveals Blind SQL Injection in `/api/results` endpoint. Exploit verified safely inside lab with zero disruption.
- **Step 5:** Phase 5 (Reporting & Disclosure): Tester generates Form 8.2 (Finding Report) registering CVSS 9.1 (Critical). System triggers 30-day remediation embargo and dispatches encrypted notification to System Owner.
- **Step 6:** Phase 6 (Remediation & Closure): System development team rewrites API using prepared statements. Tester re-tests in isolated lab, verifies vulnerability eradication, and issues Final Closure Certificate.

9.2 Systematic Framework Stress Test Cases

The framework was subjected to four edge-case stress scenarios to verify defensive failure handling (Table 9.1).

Stress Test Scenario	Simulated Fault Condition	Theoretical Failure Mode	Observed Framework Defensive Action
ST-01: Missing Authorization	Internal tester initiates port scan against LMS staging before CISO signature is attached.	Unauthorized probing under IT Act Section 43.	PASS: Automated edge switch sensor drops packets from unauthenticated MAC; incident alert dispatched to CISO.

ST-02: Out-of-Scope Targeting	Assessor enters campus Core Switch IP (`10.10.1.1`) into automated lab vulnerability scanner.	Potential collapse of live campus WAN backbone routing.	PASS: Network boundary validator intercepts scan target; flags IP as OUT-OF-SCOPE; immediately terminates scan process.
ST-03: Legal / Privacy Conflict	Department requests live vulnerability scan against active production fee payment database.	Catastrophic financial data breach under DPDP Act 2023.	PASS: Scope engine detects PII database tag; enforces mandatory DPO block; requires migration to synthetic testbed.
ST-04: Remediation Past Window	System Owner fails to patch Critical SQLi finding after 30-day embargo expires without update.	Exposure of unpatched critical vulnerability without resolution.	PASS: Automated governance trigger escalates issue to Vice-Chancellor; initiates mandatory CERT-In notification protocol.

9.3 Walkthrough Observations and Governance Refinements

Evidence-Based Refinements: The walkthrough revealed two significant operational vulnerabilities in the initial framework design, which were systematically corrected:

- **Refinement 1 (Automated Scoping):** Defect 1 (Manual Scope Checking Latency): Originally, target IP addresses were manually cross-referenced against an Excel asset register. During high-intensity scanning, this caused delayed identification of unlisted IPs. Refinement: Integrated an automated JSON asset-tag validation engine directly into the pre-engagement firewall rules, rejecting untagged packets within 2 milliseconds.
- **Refinement 2 (Fixed Remediation Rules):** Defect 2 (Ambiguous Disclosure Escalation): The original draft specified an ambiguous 'reasonable remediation window' for all vulnerabilities. This resulted in developers de-prioritizing critical findings. Refinement: Implemented the rigid binary standard: exactly 30 calendar days for Critical vulnerabilities (CVSS >= 9.0) and exactly 90 calendar days for High/Medium vulnerabilities.

Task 10: Scalability and Governance Evaluation

10.1 Experimental Design: Small Department vs. Enterprise University Programme

To evaluate framework scalability as the institution expands from an initial pilot to university-wide adoption including external assessors, a comparative stress evaluation was conducted across two contrasting operational scales:

- **Baseline Environment:** Small Programme (Baseline Pilot): 1 Academic Department, 5 Target Systems, 2 Internal Testers.
- **Enterprise Environment:** Large Programme (Campus-Wide Enterprise): Entire University Infrastructure, 200 Target Systems, 20 Internal Testers + 10 External Third-Party Assessors.

10.2 Empirical Process Metrics Comparison

Three critical operational processes were monitored and quantified: (1) Total Approval Turnaround Time from request to authorization, (2) Verified Scope Coverage across deployed digital assets, and (3) Total Procedural Steps required for vulnerability disclosure. Table 10.1 and Figure 10.1 summarize the empirical results.

Performance Metric	Small Programme (1 Dept, 5 Systems)	Large Programme (Campus-Wide, 200 Systems)	Observed Operational Variance & Scalability Bottleneck
Approval Turnaround Time	4.0 Hours	36.0 Hours	+800% latency increase. High-volume manual executive review creates severe bureaucratic approval bottlenecks.
Verified Scope Coverage	100.0% Asset Coverage	82.0% Asset Coverage	-18.0% coverage loss. Dynamic microservices and unmanaged departmental assets escape scheduled assessment cycles.
Vulnerability Disclosure Steps	5 Discrete Steps	9 Discrete Steps	+80% procedural overhead. External vendor onboarding, dual NDA sign-offs, and multi-tier re-testing increase step count.

10.3 Governance Refinements Derived from Empirical Evidence

Actionable Governance Improvements: Rather than treating metrics as passive observations, the governance team utilized this empirical evidence to implement three structural governance refinements to preserve institutional efficiency at enterprise scale:

- **Refinement A (Tiered Approvals):** Delegated Hierarchical Approval Matrix: To eliminate the 36-hour approval bottleneck, authority for low-risk staging systems was delegated to Departmental IT Security Leads, while CISO/DPO sign-off is reserved strictly for systems touching personal data or core campus routing.
- **Refinement B (Dynamic Prioritization):** Risk-Based Dynamic Scheduling Engine: To resolve the 18% scope coverage gap, manual scheduling was replaced with automated risk scoring. Assets holding sensitive student records or public-facing exposure are queued for continuous automated re-scans every 14 days, while low-criticality subnets are evaluated semi-annually.
- **Refinement C (Standardized Onboarding):** Automated External Assessor Onboarding Pipeline: Standardized digital NDAs, cryptographic hardware security module (HSM) credential provisioning, and automated containerized lab access reduced external onboarding disclosure steps from 9 to 6 standardized phases.

Task 11: Defend the Framework Under Changed Requirements

11.1 The Changed Operating Requirement

The University Management has revised its strategic operating model: testing must transition from episodic point-in-time assessments to Continuous Security Testing; external third-party assessors will conduct regular evaluations; data protection regulations have tightened under full enforcement of the DPDP Act 2023; and the disclosure remediation window must be aggressively compressed to minimize vulnerability exposure.

11.2 Framework Architectural Evolution: Retain, Modify, Replace, Redesign

To accommodate these rigorous requirements while maintaining structural governance, the framework architecture was methodically revised (Table 11.1).

Component Lifecycle Action	Target Governance Component	Detailed Technical Modification	Strategic Rationale & Regulatory Justification
RETAIN	Core Scope & RoE	Preserve rigid scope tagging	These architectural controls

	Standards (Task 5) and Host-Only Lab Isolation (Task 7)	and zero-production-risk host-only lab virtualization.	provide mathematically verifiable protection against production damage and legal exposure.
MODIFY	Responsible Disclosure Protocol (Task 6) and Legal Compliance Matrix (Task 4)	Compress Critical remediation window from 30 days to 7 days (90 to 30 for non-critical); integrate DPDP 2023 heavy breach penalty obligations.	Aligns framework with rapid threat landscape; prevents statutory penalties up to Rs 250 Crores under new data protection laws.
REPLACE	Manual Spreadsheet & PDF Approval Tracking (Task 6 & 8)	Decommission manual forms; deploy an automated API-driven Governance, Risk & Compliance (GRC) workflow engine.	Manual tracking collapses under enterprise scale. Automated GRC engine provides cryptographic non-repudiation and real-time SLA tracking.
REDESIGN	Episodic Engagement Lifecycle (Task 1 & 9)	Transition from manual ad-hoc testing to a Continuous Automated Assessment Pipeline integrated into university CI/CD deployments.	Code updates occur weekly; periodic manual tests leave long windows of unassessed vulnerability exposure in staging pipelines.

11.3 New Component Specification: The External-Assessor Governance Module (EAGM)

To govern external commercial penetration testing firms and third-party ethical hacking contractors safely, the framework incorporates a specialized sub-module: the External-Assessor Governance Module (EAGM). This module enforces three mandatory layers:

- **EAGM Layer 1:** Layer 1 (Vetting & Legal Indemnification): Mandatory institutional vetting, proof of professional liability insurance (minimum Rs 5 Crore indemnity coverage), and execution of a tripartite non-disclosure and personal data indemnity agreement countersigned by university legal counsel.
- **EAGM Layer 2:** Layer 2 (Zero-Trust Identity & Session Recording): External assessors are barred from direct VPN bridging. All external connections terminate at a Bastion Host with dual-factor authentication (MFA); 100% of terminal commands, packet captures, and GUI interactions are recorded as tamper-evident video and text audit streams.
- **EAGM Layer 3:** Layer 3 (Micro-Segmented Lab Provisioning): External assessors receive ephemeral, isolated host-only lab environments automatically spun up via containerized infrastructure. Assessor access automatically expires when the authorized window reaches 00:00 IST.

11.4 Evidence-Based Defence of the Final Framework

The final framework stands fully defended by empirical evidence gathered across all development phases: The Walkthrough (Task 9) proved the end-to-end viability of the 6-phase lifecycle from request to patched closure; the Legal Compliance Mapping (Task 4) demonstrated concrete protection against IT Act 2000 Section 43/66 criminal liability; the Isolated Lab Design (Task 7) empirically proved zero packet leakage to production LANs; and the Scalability Refinements (Task 10) demonstrated how tiered delegation and automated asset tagging sustain high operational velocity even across 200+ systems.

11.5 Explicit Trade-Offs, Residual Limitations, and Future Roadmap

Residual Institutional Trade-Offs: A rigorous engineering defense acknowledges inherent architectural trade-offs. The framework identifies two prominent operational trade-offs and charts targeted future enhancements:

- **Trade-Off 1:** Trade-Off 1 (Remediation Velocity vs. Development Burnout): Compressing the Critical vulnerability disclosure window from 30 days to 7 days dramatically reduces the window of institutional vulnerability exposure. However, it severely strains academic software development staff, potentially causing patch errors or fatigue-induced regressions. Future Roadmap: Deploy automated virtual patching via Web Application Firewalls (WAF) to provide immediate temporary shielding while underlying codebases are methodically refactored.
- **Trade-Off 2:** Trade-Off 2 (Security Containment vs. Behavioral Realism): Confining all exploitation to an isolated host-only lab guarantees zero production disruption. However, artificial lab environments cannot fully simulate complex, distributed production traffic flows, load conditions, or third-party cloud API dependencies. Future Roadmap: Implement automated digital twin replication of production cloud infrastructure using Infrastructure-as-Code (Terraform) scripts, creating high-fidelity, ephemeral testing sandboxes.